

Il faut créer une PSSI pour le labo, par défaut elle s'appuie sur la PSSI du CNRS
On va se répartir le travail, je compléterai ce qui est spécifique
d'abord dans ce pad pour finir avec un document Word sur le cloud.

1 - Chercher des exemples de PSSI dans des EPST, des labo de math, école centrale, polytech, INRIA, INRAE, ...

2 - Choisir une partie du document à remplir

https://slideplayer.fr/slide/4802075/?utm_source=chatgpt.com

<https://openclassrooms.com/fr/courses/1734201-definissez-la-politique-de-securite-de-votre-entreprise/6206377-mettez-en-oeuvre-la-pssi-efficacement>

<https://www.cybermalveillance.gouv.fr/mon-espace/connectez-vous>

https://ssi.univ-lille.fr/fileadmin/user_upload/ssi/documents/universite_de_lille-pssi.pdf

Structure type d'une PSSI pour un laboratoire de mathématiques

Introduction - Fabio

Objectifs de la PSSI:

- **1. Garantir l'intégrité des données:**
- -Protéger les travaux de recherche non publiés, projets confidentiels (ex : collaborations industrielles).
- -Assurer la protection des données personnelles (étudiants, chercheurs, secrétaires, partenaires)
- **2. Assurer l'intégrité des systèmes et des données:**
- -Prévenir toute altération non autorisée des codes, résultats ou publications scientifiques.
- -Garantir la validité des calculs, simulations et preuves stockées.
- **3. Assurer la disponibilité des ressources :**
- -Maintenir l'accès aux outils informatiques, serveurs de calcul, plateformes collaboratives.
- -Prévenir les interruptions de service (cyberattaques, pannes, erreurs humaines).
- **4. Encadrer les usages informatiques:**
- -Définir les règles d'usage des postes, serveurs, logiciels et réseaux.
- -Contrôler l'accès aux ressources (accès VPN, comptes, authentification forte).
- **5. Conformité réglementaire et contractuelle:**
- -Respecter les lois en vigueur (RGPD, droit d'auteur, sécurité numérique).

- -Répondre aux exigences des partenaires (ANR, CNRS, ERC, entreprises, etc.).
- **6. Sensibiliser les utilisateurs:**
- -Former les chercheurs, doctorants, enseignants, techniciens à la sécurité numérique.
- -Développer une culture de la sécurité informatique dans le labo.
- **7. Suivre et réagir aux incidents:**
- -Mettre en place un dispositif de détection et de réponse aux incidents (logs, alertes, procédures de crise).
- -Apprendre des incidents passés pour améliorer la sécurité.

Gouvernance et responsabilités - SALIM

Rôle du directeur de l'unité

La PSSI du CNRS stipule que le directeur d'unité est responsable de la mise en œuvre de la politique de sécurité des systèmes d'information dans son unité. Il doit notamment

- Élaborer un plan d'action pluriannuel pour la mise en œuvre de la PSSI, en tenant compte des ressources nécessaires.
- Nommer un Chargé de la Sécurité des Systèmes d'Information (CSSI) pour l'unité, qui sera intégré aux chaînes fonctionnelles SSI des tutelles.
- S'assurer que les documents de PSSI de l'unité sont en accord avec ceux de toutes ses tutelles.

Désignation du Responsable de la Sécurité des Systèmes d'Information (RSSI)

La PSSI du CNRS prévoit la désignation d'un RSSI au niveau national et régional. Le RSSI est chargé de :

- Mettre en œuvre la politique générale de sécurité de l'information du CNRS.
- Identifier et analyser les risques liés aux systèmes d'information.
- Suivre les incidents de sécurité et accompagner les laboratoires lors d'incidents.
- Sensibiliser et former les personnels aux enjeux de sécurité des systèmes d'information.

Coordination avec les tutelles (CNRS, université, etc.)

Dans le cas des unités mixtes, la PSSI du CNRS prévoit que :

- Une des tutelles est identifiée comme pilote de la SSI.
- Le pilote définit, en lien avec les tutelles, la PSSI opérationnelle et la Charte SSI qui s'appliqueront à l'unité.
- Le directeur d'unité nomme un CSSI qui est intégré aux chaînes fonctionnelles SSI des tutelles.

- Tout incident SSI est signalé à l'ensemble des chaînes fonctionnelles SSI des tutelles.

Gestion des risques - ENZO

Identification des actifs critiques (données de recherche, codes sources, etc.) :

- données de recherche : Les résultats de recherche, les publications en cours, et les ensembles de données expérimentales.
- codes sources : Les logiciels et algorithmes développés par les membres du laboratoire.
- Équipements informatiques : Les serveurs, les postes de travail, et les dispositifs de stockage de données.
- Ressources humaines : Les compétences et les connaissances des chercheurs et du personnel technique.

Analyse des menaces potentielles

- Cyberattaques : Les attaques par malware, phishing, et ransomware qui pourraient compromettre la confidentialité, l'intégrité et la disponibilité des données.
- Erreurs humaines : Les erreurs de manipulation, les pertes de données, et les violations involontaires des politiques de sécurité.
- Défaillances matérielles : Les pannes de matériel qui pourraient entraîner des pertes de données ou des interruptions de service.

Mesures de protection mises en place

Les ordinateurs sont cryptés, sauvegardé par des scripts, mis à jours par des scripts
....

Les postes des secrétariats sont ...

- il faut protéger les poste de travail avec antivirus, de pare-feu, mots de passe et pourquoi pas d'A2F
- former le personnel pour éviter des erreurs pour la sécurité

Mesures de sécurité - Sofian

Contrôle des accès

- Authentification forte : Mise en place d'une authentification à deux facteurs (2FA) pour les accès aux systèmes sensibles.

- Gestion des identités : Utilisation d'un annuaire centralisé pour la gestion des comptes utilisateurs, avec des processus d'approbation pour la création, la modification et la suppression des comptes.
- Moindre privilège et revue des droits : Les droits sont limités aux besoins réels des utilisateurs. Une vérification régulière permet de retirer les accès obsolètes (ex. : départ d'un stagiaire).

Sauvegardes et archivage

- Plan de sauvegarde : Élaboration d'une politique de sauvegarde définissant la fréquence, le type et rétention des sauvegardes.
- Stockage sécurisé : Conservation des sauvegardes dans des emplacements sécurisés, avec des copies hors site pour prévenir les risques locaux.
- Tests de restauration : Réalisation régulière de tests de restauration pour vérifier l'efficacité des procédures de sauvegarde.
- Archivage réglementaire : Mise en place de procédures d'archivage conformes aux obligations légales et institutionnelles (ex. : 5 ans pour les dossiers financiers).

Sécurité des réseaux et des postes de travail

- Pare-feu et filtrage : Déploiement de pare-feu pour contrôler le trafic entrant et sortant, avec des règles de filtrage adaptées.
- Segmentation du réseau : Division du réseau en segments pour limiter la propagation des incidents de sécurité.
- Mises à jour régulières : Application systématique des correctifs de sécurité sur les systèmes d'exploitation et les logiciels utilisés.
- Antivirus et antimalware : Installation et mise à jour régulière de solutions de protection contre les logiciels malveillants.
- Sensibilisation des utilisateurs : Formation des utilisateurs aux bonnes pratiques de sécurité, notamment en matière de phishing et de gestion des mots de passe.

Gestion des incidents

- Procédure de gestion des incidents : Élaboration d'un processus clair pour la détection, la notification, l'analyse et la résolution des incidents.
- Journalisation : Collecte automatique des logs système et réseau pour retracer les événements en cas d'alerte.
- Contact avec le CERT : Si incident majeur, coordination avec le CERT du CNRS ou du site.
- Retour d'expérience : Chaque incident donne lieu à une synthèse, pour prévenir une répétition (ex. : changement de configuration, renforcement de mot de passe).

Conformité et obligations légales - Stevan

-----Respect du
RGPD-----

Même si les chercheurs travaillent souvent sur des **modèles abstraits**, plusieurs cas d'usage impliquent **des données personnelles** et donc une nécessité d'avoir des **mesures de sécurité formalisées dans une PSSI**.

*

art. 32 à 36 : obligation de garantir la sécurité des données personnelles.

-----Conformité aux normes
CNIL-----

Tenue d'un registre des traitements :

- Obligation CNIL : Obligatoire pour tout organisme public, y compris les laboratoires.
- Lien avec la PSSI : Le registre doit inclure les mesures de sécurité mises en place, souvent décrites dans la PSSI.

Mise en œuvre de mesures de sécurité :

- Obligation CNIL : Obligatoire (conformément à l'article 32 du RGPD).
- Lien avec la PSSI : C'est un élément central. La PSSI doit détailler les mesures techniques (chiffrement, contrôle d'accès, sauvegardes, etc.).

Information des personnes concernées :

- Obligation CNIL : Obligatoire au nom de la transparence.
- Lien avec la PSSI : La PSSI peut préciser les responsabilités liées à cette information, notamment dans les projets de recherche ou la gestion interne.

Notification des violations de données :

- Obligation CNIL : Obligatoire en cas de fuite, perte ou accès non autorisé à des données personnelles.
- Lien avec la PSSI : Elle doit contenir une procédure de détection, de gestion et de notification des incidents.

Analyse d'impact sur la protection des données (AIPD) :

- Obligation CNIL : Obligatoire uniquement pour les traitements à risques (exemple : données de santé, comportementales, ou sensibles).
- Lien avec la PSSI : La PSSI peut inclure une règle de déclenchement de l'analyse d'impact et encadrer son déroulement.

-----Obligations contractuelles liées aux partenariats de recherche-----

Dans le cadre des collaborations scientifiques, nationales ou internationales, le laboratoire peut être amené à participer à des projets de recherche financés ou cofinancés par des organismes publics (ex. ANR, Europe), des établissements privés, ou d'autres structures académiques. Ces partenariats donnent lieu à des engagements contractuels qui incluent des exigences spécifiques en matière de sécurité des systèmes d'information.

À ce titre, le laboratoire s'engage à :

- Respecter les clauses contractuelles relatives à la **confidentialité**, à la **protection des données**, à la **propriété intellectuelle**, et à la **sécurité des échanges d'information** ;
- Mettre en œuvre des mesures de sécurité adaptées au niveau de sensibilité des données échangées, telles que définies dans le contrat ou le plan de gestion des données associé au projet ;
- Restreindre l'accès aux ressources informatiques du projet aux seules personnes habilitées, identifiées par les responsables scientifiques, et maintenir un registre des accès ;
- Informer sans délai le responsable sécurité de l'établissement ou du laboratoire en cas d'incident de sécurité affectant un partenariat de recherche (accès non autorisé, perte de données, etc.) ;
- Garantir la conformité des traitements de données personnelles avec le Règlement général sur la protection des données (RGPD) et, le cas échéant, réaliser une **analyse d'impact (AIPD)** en lien avec le DPO de l'établissement ;
- Prendre en compte, lorsque nécessaire, les référentiels de sécurité du ou des partenaires, notamment en matière de **stockage, chiffrement, journalisation et traçabilité** ;
- Assurer une **sensibilisation spécifique** des personnels impliqués dans un projet comportant des obligations SSI renforcées.

Ces engagements sont rappelés à chaque signature de contrat ou convention de partenariat impliquant un traitement de données ou une utilisation du système d'information du laboratoire.

Sensibilisation et formation - Axel

Objectifs : -Informer et responsabiliser les utilisateurs face aux risques numériques
-Réduire les comportements à risque (ex. : clics sur des liens suspects, mots de passe faibles)
-Renforcer la capacité de détection et de réaction en cas d'incident

Public concerné : Etudiants, enseignants-chercheurs, personnel administratif

- **Programmes de sensibilisation à la sécurité pour le personnel**
 - Campagnes annuelles (affiches, mails, bannières) - Thème phishing, mots de passe, RGPD
 - Partager les risques liés à une fuite de données
 - Montrer les différentes menaces qui existent sur internet aujourd'hui
 - Simulations d'attaque (faux mails de phishing) pour tester les réactions des utilisateurs et ajuster les formations
 - Affichage de messages clairs dans les salles de pause/BU/caféteria
 - Partage d'exemples concrets de fuites de données et leur conséquences
 - Présentation des différentes menaces actuelles sur Internet (ransomware, usurpation d'identité, malwares, etc.)
- **Formations spécifiques pour les nouveaux arrivants**
 - Intégration des réflexes quant aux différents moyens de vérifier la provenance et la viabilité d'un message/d'une information
 - Présentation du cadre réglementaire (RGPD, charte informatique de l'université, responsabilité individuelle)
 - **Ateliers pratiques** (1 à 2 fois par an)
 - Créer un mot de passe robuste
 - Sécuriser son poste de travail
 - Identifier un message frauduleux
- **Outils pédagogiques et supports**

- Guide de bonne pratique numérique accessible sur le Wiki de l'université
- Remise d'un livret de cybersécurité
- Modules e-learning obligatoires pour les nouveaux personnels et les responsables de données :
 - Introduction à la cybersécurité
 - Sécurité des données personnelles
 - Réaction aux incidents

● **Evaluation et amélioration continue**

- Évaluation des connaissances via quiz ou tests post-formation.
- Statistiques de participation aux formations et ateliers
- Analyse des résultats des simulations d'attaque pour ajustement des contenus
- Mise à jour annuelle des contenus pédagogiques en lien avec la DSI et le RSSI
- Enquête annuelle de satisfaction et de retour d'expérience sur les formations reçues

Articulation d'une PSSI : - Djib

4 éléments clés pour mettre en place une PSSI :

- 1) Qui vous êtes, ce que vous faites et quels sont vos objectifs en terme de sécurité ? Mise en place d'un périmètre, inclus ou non dans la PSSI
- 2) Analyse des risques et objectifs en terme de sécurité
- 3) Expliquer les mesures de sécurité
- 4) Sensibiliser les collaborateurs